

Why Computer Security

- There is an explosion in concerns for the security of information
- Jobs and salaries for technology professionals have lessened in recent years. BUT ...
- Security specialists markets are expanding!

Why Computer Security (cont'd)

- Internet attacks are increasing in frequency, severity and sophistication
- Denial of service (DoS) attacks
 - Cost \$1.2 billion in 2000
 - 1999 CSI/FBI survey 32% of respondents detected DoS attacks directed to their systems
 - Thousands of attacks per week in 2001
 - Yahoo, Amazon, eBay, Microsoft, White House, etc., attacked

Why Computer Security (cont'd)

- Virus and worms faster and powerful
 - Melissa, Nimda, Code Red, Code Red II, Slammer ...
 - Cause over \$28 billion in economic losses in 2003, growing to over \$75 billion in economic losses by 2007.
 - Code Red (2001): 13 hours infected >360K machines - \$2.4 billion loss
 - Slammer (2003): 10 minutes infected > 75K machines - \$1 billion loss
- Spams, phishing ...
- New Internet security landscape emerging:
BOTNETS !

Overview

- Course Details
- What is security: history and definition
- Security policy, mechanisms and services
- Security models

Course Objective

- Understand the basic principles for information and communication security, and be able to apply these principles to evaluate and criticize information system security properties
- Be able to use some important and popular security tools, like encryption, digital signatures, firewalls, intrusion detection systems (IDS)
- Be able to identify the vulnerability of the Internet systems and recognize the mechanisms of the attacks, and apply them to design and evaluate counter-measure tools

Course Contents

- Cryptography
 - Secret key algorithms: DES/AES
 - Public key algorithms: RSA
 - One-way hash functions & message digests: MD5, SHA2
- Authentication, access control, public key infrastructure (PKI, briefly)
 - Case study: Kerberos
- Internet vulnerability
 - Denial-of-service attacks
 - Viruses, worms, Trojan horses

Course Contents (cont'd)

- Securing the Internet
 - Intrusion detection systems (IDSs): host- vs. network-based, signature vs. statistical detection
 - Case study: Snort and Bro
 - Firewalls, VPN and IPsec
- Software security
 - Buffer overflow, heap overflow and string format bugs
 - Detection techniques: static program analysis vs. run-time detection
- Operating system security
 - Dealing with bad (legacy) codes: sandboxing
 - Multi-level security, file system security

Overview

- Course Administrative Trivia
- What is security: history and definition
- Security policy, mechanisms and services
- Security models

The History of Computing

- For a long time, security was largely ignored in the community
 - The computer industry was in "survival mode", struggling to overcome technological and economic hurdles
 - As a result, a lot of corners were cut and many compromises were made
 - There was lots of theory, and even examples of systems built with very good security, but were largely ignored or unsuccessful
 - E.g., ADA language vs. C (powerful and easy to use)

Computing Today is Very Different

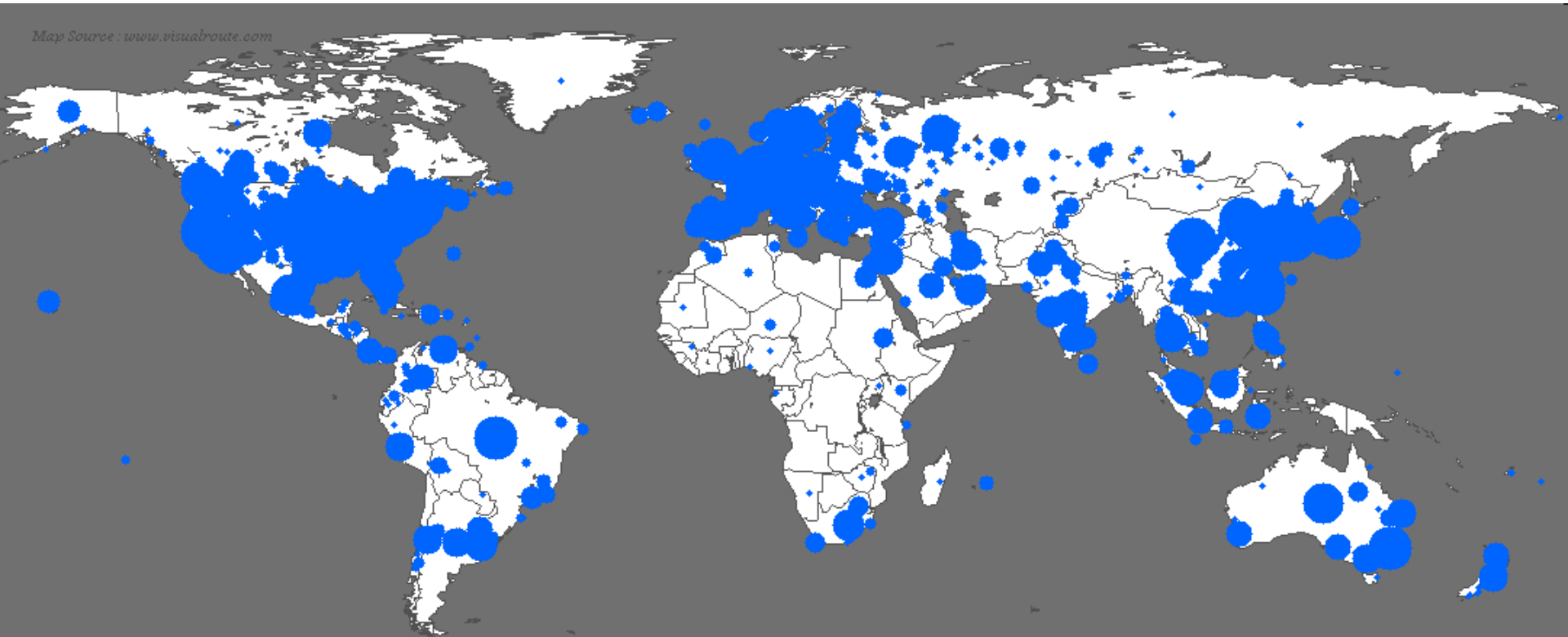
- Computers today are far from “survival mode”
 - Performance is abundant and the cost is very cheap
 - As a result, computers now ubiquitous at every facet of society
- Internet
 - Computers are all connected and interdependent
 - This codependency magnifies the effects of any failures

Biological Analogy

- Computing today is very homogeneous.
 - A single architecture and a handful of OS dominates
- In biology, homogeneous populations are in danger
 - A single disease or virus can wipe them out overnight because they all share the same weakness
 - The disease only needs a vector to travel among hosts
- Computers are like the animals, the Internet provides the vector.
 - It is like having only one kind of cow in the world, and having them drink from one single pool of water!

The Spread of Sapphire/Slammer Worms

Map Source : www.visualroute.com



Sat Jan 25 06:00:00 2003 (UTC)

Number of hosts infected with Sapphire: 74855

<http://www.caida.org>

Copyright (C) 2003 UC Regents

The Flash Worm

- Slammer worm infected 75,000 machines in <15 minutes
- A properly designed worm, flash worm, can take less than 1 second to compromise 1 million vulnerable machines in the Internet
 - [The Top Speed of Flash Worms](#). S. Staniford, D. Moore, V. Paxson and N. Weaver, ACM WORM Workshop 2004.
 - Exploit many vectors such as P2P file sharing, intelligent scanning, hitlists, etc.

The Definition of Computer Security

- *Security* is a state of well-being of information and infrastructures in which the possibility of successful yet undetected theft, tampering, and disruption of information and services is kept low or tolerable
- Security rests on confidentiality, authenticity, integrity, and availability

The Basic Components

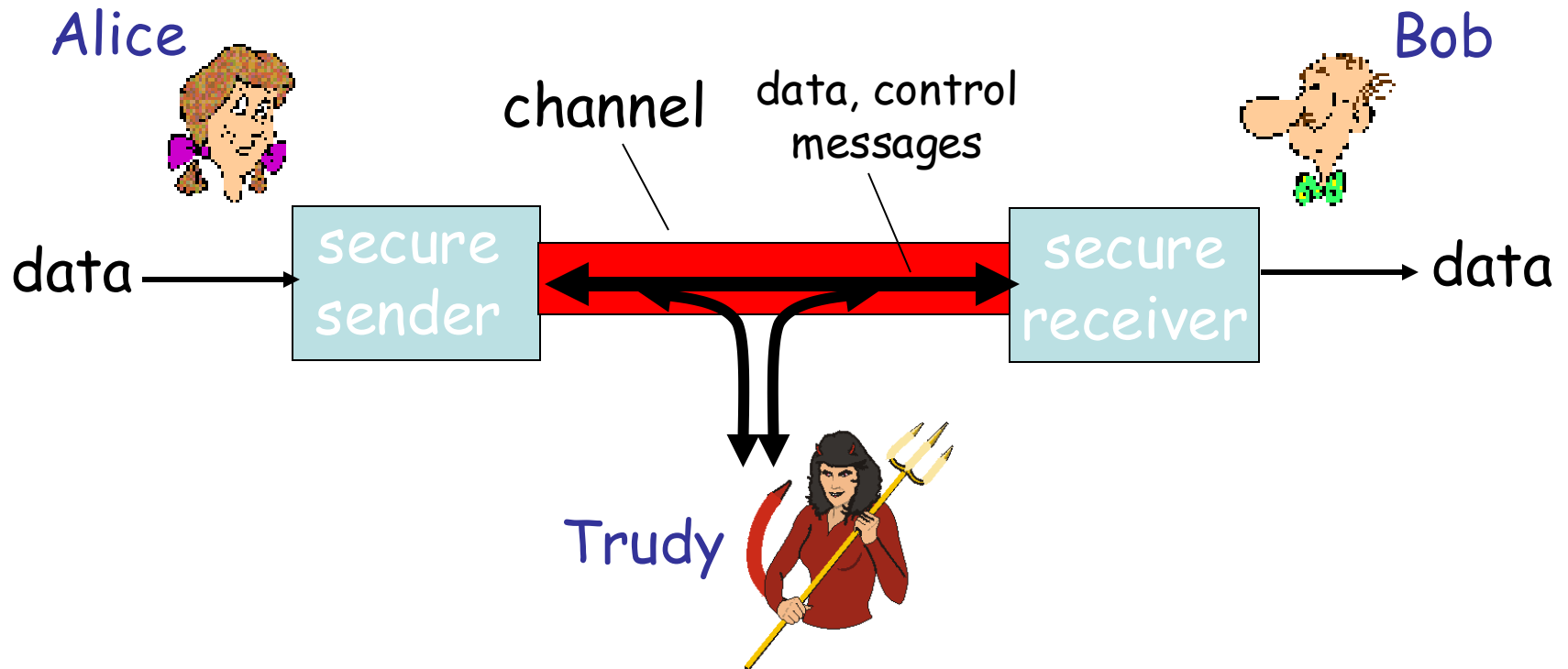
- **Confidentiality** is the concealment of information or resources.
 - E.g., only sender, intended receiver should “understand” message contents
- **Authenticity** is the identification and assurance of the origin of information.
- **Integrity** refers to the trustworthiness of data or resources in terms of preventing improper and unauthorized changes.
- **Availability** refers to the ability to use the information or resource desired.

Security Threats and Attacks

- A threat/vulnerability is a *potential* violation of security.
 - Flaws in design, implementation, and operation.
- An attack is any *action* that violates security.
 - Active adversary
- An attack has an implicit concept of "intent"
 - Router mis-configuration or server crash can also cause loss of availability, but they are not attacks

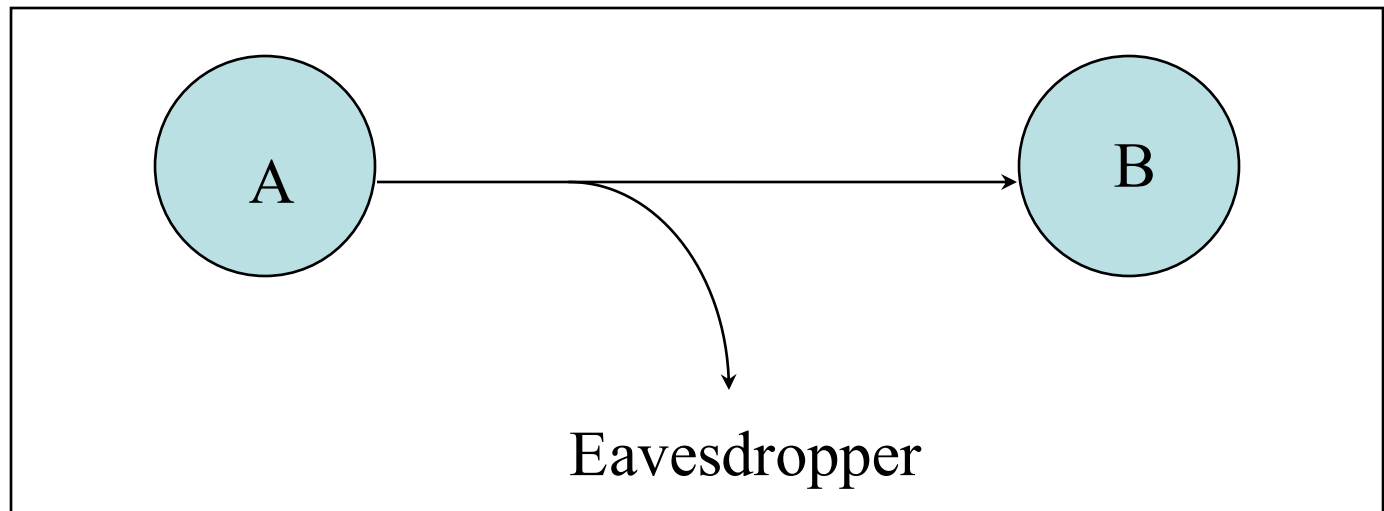
Friends and enemies: Alice, Bob, Trudy

- well-known in network security world
- Bob, Alice (lovers!) want to communicate "securely"
- Trudy (intruder) may intercept, delete, add messages



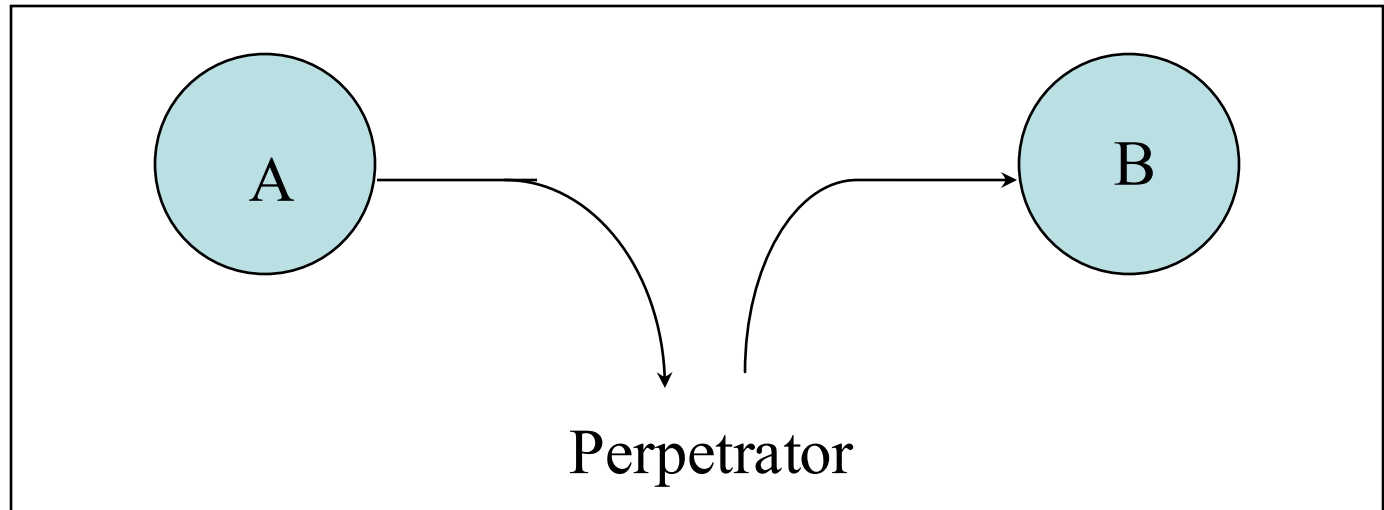
Eavesdropping - Message Interception (Attack on Confidentiality)

- Unauthorized access to information
- Packet sniffers and wiretappers
- Illicit copying of files and programs



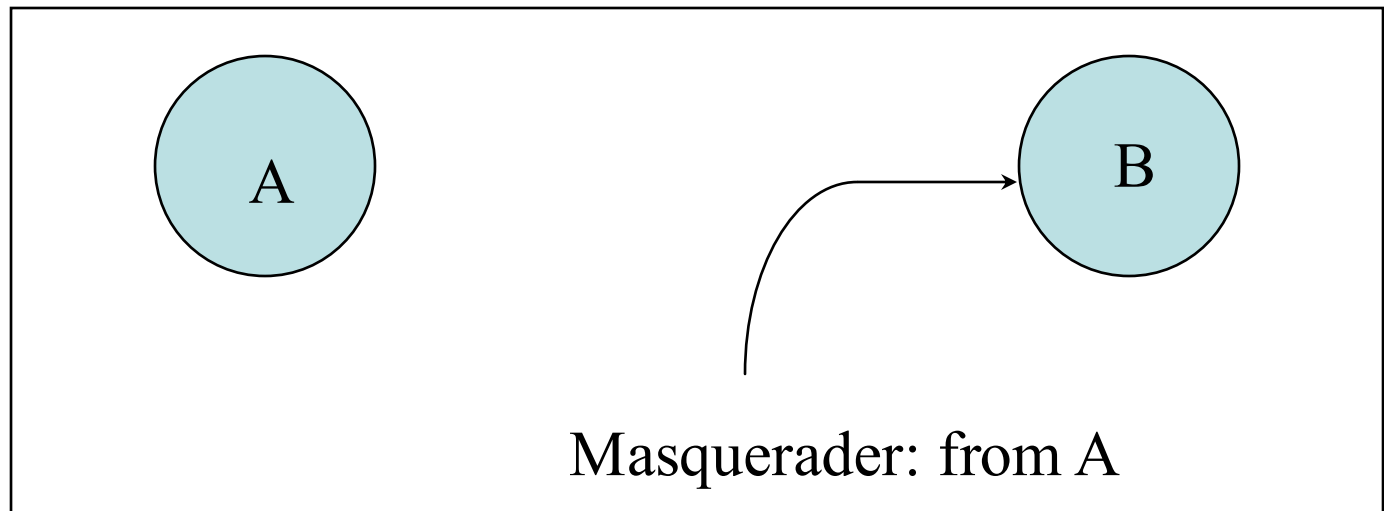
Integrity Attack - Tampering With Messages

- Stop the flow of the message
- Delay and optionally modify the message
- Release the message again



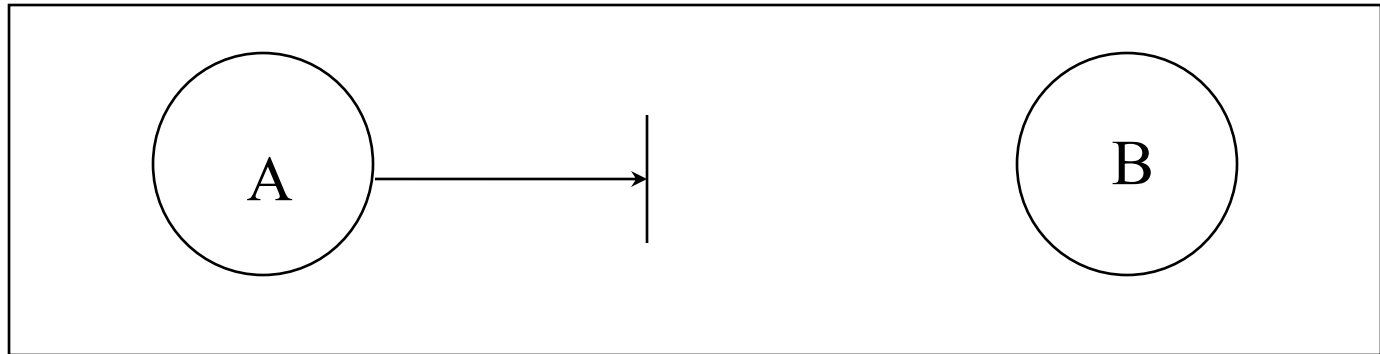
Authenticity Attack - Fabrication

- Unauthorized assumption of other's identity
- Generate and distribute objects under this identity



Attack on Availability

- Destroy hardware (cutting fiber) or software
- Modify software in a subtle way (alias commands)
- Corrupt packets in transit



- *Blatant denial of service (DoS):*
 - Crashing the server
 - Overwhelm the server (use up its resource)

Classify Security Attacks as

- **Passive attacks** - eavesdropping on, or monitoring of, transmissions to:
 - obtain message contents, or
 - monitor traffic flows
- **Active attacks** - modification of data stream to:
 - masquerade of one entity as some other
 - replay previous messages
 - modify messages in transit
 - denial of service

Overview

- Course Administrative Trivia
- What is security: history and definition
- Security policy, mechanisms and services
- Security models

Security Policy and Mechanism

- **Policy**: a statement of what is, and is not allowed.
- **Mechanism**: a procedure, tool, or method of enforcing a policy.
- Security mechanisms implement functions that help *prevent, detect, and respond to recovery* from security attacks.
- Security functions are typically made available to users as a set of **security services** through APIs or integrated interfaces.
- Cryptography underlies many security mechanisms.

OSI Security Architecture

- ITU-T X.800 Security Architecture for OSI
- Defines a systematic way of defining and providing security requirements
- For us it provides a useful, if abstract, overview of concepts we will study
- X.800 defines security services in 5 major categories

Security Services (X.800)

- **Authentication** - assurance that the communicating entity is the one claimed
- **Access Control** - prevention of the unauthorized use of a resource
- **Data Confidentiality** - protection of data from unauthorized disclosure
- **Data Integrity** - assurance that data received is as sent by an authorized entity
- **Non-Repudiation** - protection against denial by one of the parties in a communication

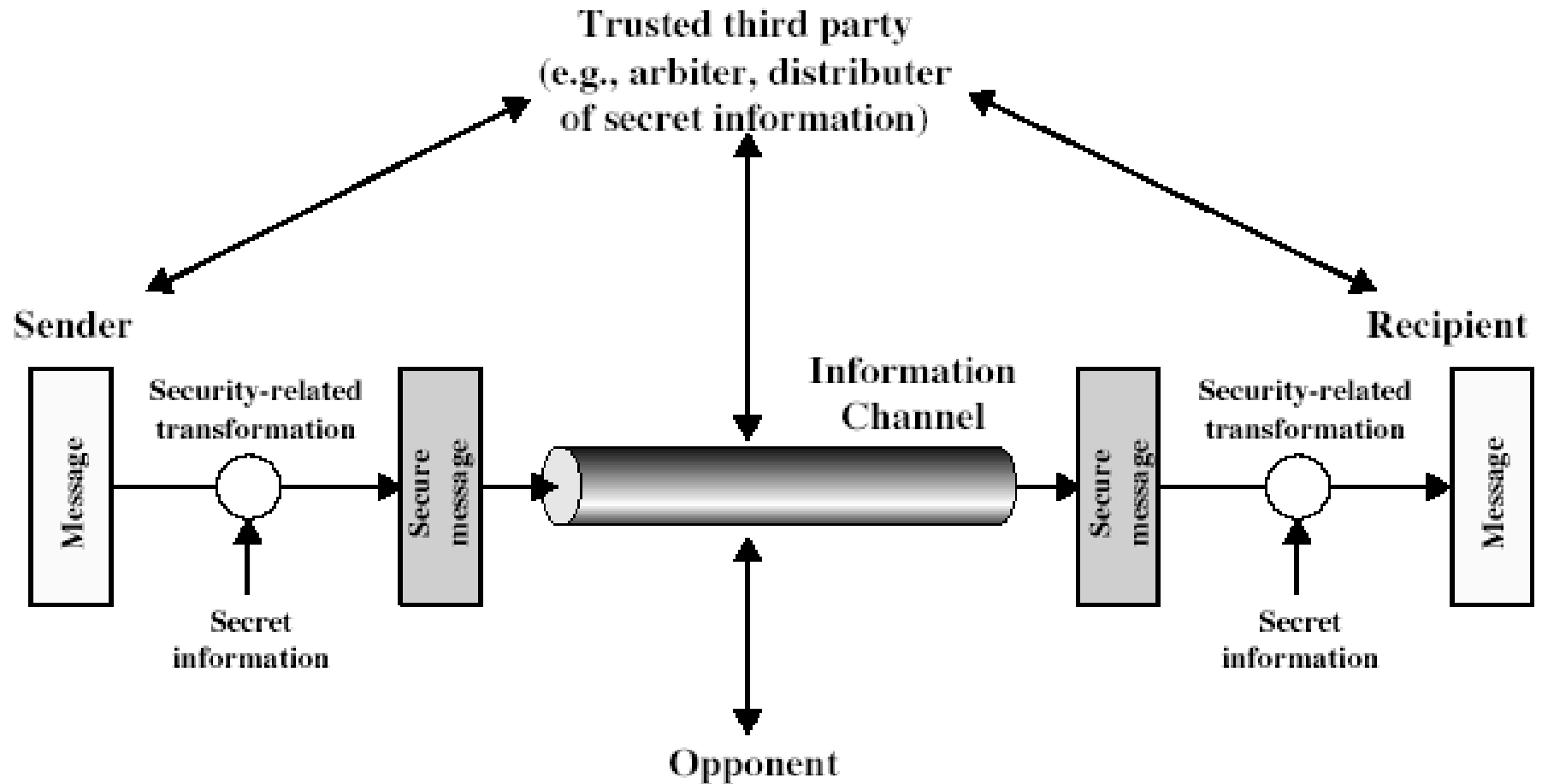
Security Mechanisms (X.800)

- Specific security mechanisms:
 - Encipherment
 - Digital signatures
 - Access controls
 - Data integrity
 - Authentication exchange
 - Traffic padding
 - Routing control
 - Notarization
- Pervasive security mechanisms:
 - Trusted functionality
 - Security labels
 - Event detection
 - Security audit trails
 - Security recovery

Overview

- Course Administrative Trivia
- What is security: history and definition
- Security policy, mechanisms and services
- Security models

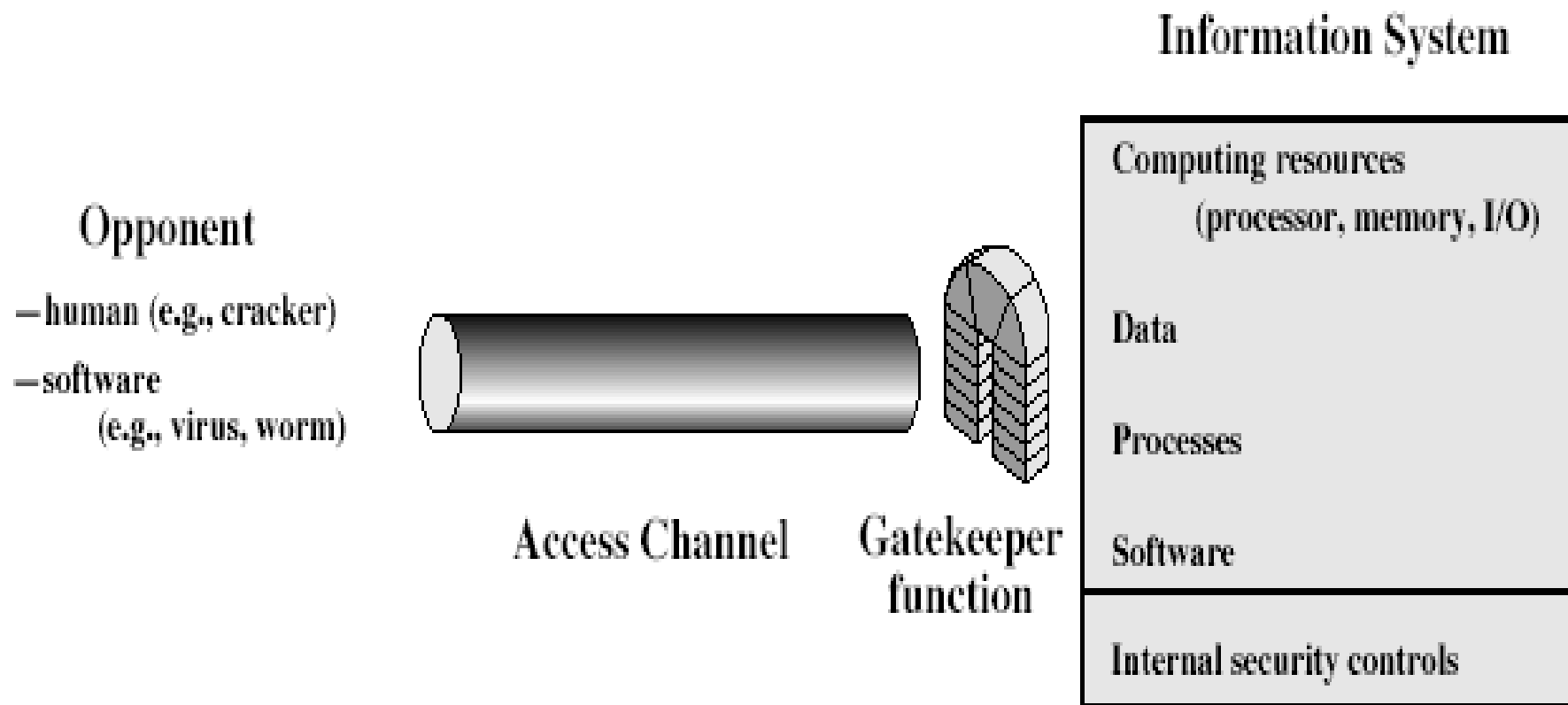
Model for Network Security



Model for Network Security

- Using this model requires us to:
 - Design a suitable algorithm for the security transformation
 - Generate the secret information (keys) used by the algorithm
 - Develop methods to distribute and share the secret information
 - Specify a protocol enabling the principals to use the transformation and secret information for a security service

Model for Network Access Security



Model for Network Access Security

- Using this model requires us to:
 - Select appropriate gatekeeper functions to identify users
 - Implement security controls to ensure only authorised users access designated information or resources
- Trusted computer systems can be used to implement this model

Backup Slides

How to Make a System Trustworthy

- Specification
 - A statement of desired functions
- Design
 - A translation of specifications to a set of components
- Implementation
 - Realization of a system that satisfies the design
- Assurance
 - The process to insure that the above steps are carried out correctly
 - Inspections, proofs, testing, etc.

The Security Life Cycle

- The *iterations* of
 - Threats
 - Policy
 - Specification
 - Design
 - Implementation
 - Operation and maintenance